



PRODUCT & TECHNICAL REPORT

ThinkBeforeClick

An Adaptive Phishing-Awareness SaaS for Individuals and Enterprises

Problem & Market · Business Model & TCO · Serverless Architecture on AWS
Phishing Simulation & CTA-Level Analytics · User Validation

PRODUCT TEAM

Zou Zhihua (Product Lead) · Ni Chenyu · Ren Yilun · Wu Yijun · Yu Jiahui

November 2025

Motivation

1.1 Problem Statement and Gaps in Existing Measures

In August 2025 alone, at least \$38,000 has been lost to a new type of scam involving fake school-fee e-mails [1]. This is not an isolated case. In the first half of 2025, scam victims in Singapore lost \$456 million across almost 20,000 reported cases [2]. Behind every number is a family, a business, or a student caught. Yet, despite countless awareness campaigns, current training remains static and outdated—one-size-fits-all and rarely tailored to the right people.

To combat increasingly sophisticated scams, many organisations run regular phishing simulations to strengthen employees' awareness. However, designing realistic, up-to-date phishing campaigns is a significant burden on security teams, who must do this work on top of their daily responsibilities and often without specialized expertise or access to the latest threat intelligence. As a result, many companies recycle the same generic training modules and outdated phishing templates year after year, while real-world attack techniques evolve rapidly. This mismatch makes current awareness programmes labour-intensive yet largely ineffective.

1.2 Proposed SaaS Solution, Target Users, Purpose

Current measures leave two clear gaps: the public lacks accessible, engaging scam education, and organisations lack an easy way to run realistic, up-to-date phishing exercises with meaningful metrics.

This project proposes an **interactive, adaptive fraud and phishing training platform** delivered as a SaaS service, targeted at both individuals and enterprises (IT/Security Teams). For individuals, it provides short modules and quizzes on common scam types such as email, with personalised recommendations based on demographic data and quiz performance. For enterprises, it adds a central dashboard and a guided tool to generate realistic phishing simulations from curated templates, send them to employees, track responses and get audit-ready reports. Employees who fall for simulations are automatically assigned follow-up training.

The initiative aims to make awareness training current, targeted, and evidence-based, while significantly reducing the manual effort required from security teams.

1.3 Comparison with Existing Market Offerings

KnowBe4 is the world's leading security awareness training and simulated phishing platform, serving tens of thousands of organisations. Table 1 shows our key strengths over the leader:

Table 1: Comparison with KnowBe4

Aspect	KnowBe4	ThinkBeforeClick
Primary Focus	Enterprise security awareness and phishing simulations	Dual focus: community literacy (public) + enterprise security awareness
Demographic-aware targeting	Up to general grouping	Individual and company level
Auto follow-up & immediate feedback	Immediate but generic	Immediate and CTA-level interaction tracking
Deep customization	General templates only	Customization upon request

Our platform differentiates itself on three fronts. First, **social impact**: a permanently free public track raises baseline scam awareness. Second, **customisation**: phishing templates are tailored to companies' domains, brands, and local scam patterns rather than relying only on generic templates. Third, **granular reporting**: results are tracked at Call-to-Action (CTA)

level (open, click, credential submit, report) rather than only at the template or campaign level, giving security teams a more detailed view of risky behaviours and training impact.

2 Business Model

2.1 Revenue Model: Free Public Track, Paid Enterprise Subscriptions

This project adopts a **freemium SaaS model**: it is free for individual users but revenue-generating from enterprises. The public track remains permanently free to maximise social impact and brand visibility. For enterprises, the platform is offered as a hosted subscription service, with tiered plans by employee count and feature set, and an optional usage-based fee by volume of phishing e-mails sent (e.g., base quota included in each plan, with top-ups for additional campaigns). On top of this, a **VIP customisation service** is available, where our team designs and maintains bespoke phishing templates and scenarios tailored to their domain, branding and local scam patterns; this is charged as a premium add-on / professional service. Together, these streams make the platform financially sustainable while keeping access free for the public.

2.2 Justification of SaaS against On-premise Implementation

To demonstrate the financial advantage of our SaaS model, we compare the total cost of ownership (TCO) between cloud deployment and on-premise implementation over a three-year period for a typical mid-sized enterprise (500 employees).

On-Premise Implementation: Initial capital expenditure totals \$28,000 (physical servers, network equipment, software licenses, installation). Annual operating costs include IT staff allocation (\$45,000), utilities (\$2,400), bandwidth (\$1,800), software maintenance (\$4,000), hardware reserves (\$2,000), and physical security (\$1,200), totaling \$56,400 per year. **Three-year total: \$197,200.**

Cloud SaaS Implementation: Monthly AWS infrastructure costs \$114 (Lambda, API Gateway, DynamoDB, S3, Cognito, SES, CloudWatch, CloudFront). Additional costs include one-time platform development (\$15,000), quarterly maintenance (\$3,000), and technical support (\$18,000/year). **Three-year total: \$109,104** (infrastructure \$4,104 + development \$15,000 + maintenance \$36,000 + support \$54,000).

Cost Savings: The SaaS model achieves **\$88,096 savings (45% reduction)** over three years, with \$13,000 lower initial investment and \$25,032 lower annual operating costs.

Table 2: Cost Savings Summary

Metric	On-Premise	Cloud SaaS	Savings
3-Year TCO	\$197,200	\$109,104	\$88,096 (45%)
Initial Investment	\$28,000	\$15,000	\$13,000
Annual Operating Cost	\$56,400	\$31,368	\$25,032

2.3 Additional SaaS Advantages

Beyond direct savings, our cloud model provides: (1) **Scalability**—automatic scaling from 100 to 10,000+ employees without hardware upgrades; (2) **Reduced time-to-value**—operational in 1-2 weeks versus 2-3 months for on-premise; (3) **Automatic updates**—security patches and features deployed without downtime; (4) **Disaster recovery**—AWS built-in redundancy with 99.99% uptime SLA versus costly duplicate on-premise infrastructure; (5) **Compliance**—AWS SOC 2 and ISO 27001 certifications included versus dedicated audit costs on-premise; and (6) **Strategic focus**—IT resources redirected from infrastructure maintenance to security

initiatives. These factors make SaaS not only more cost-effective but also more agile, secure, and strategically aligned with modern enterprise needs.

3 Architecture and Implementation

3.1 System Overview

Our cloud service is composed of specialized microservices and managed AWS components (Figure 1). The platform separates concerns across an authentication layer (AWS Cognito), a stateless API and service layer (API Gateway and Lambda), and a data storage layer (DynamoDB and S3). Auxiliary managed services (SES, CloudWatch, IAM) minimize operational overhead and improve reliability.

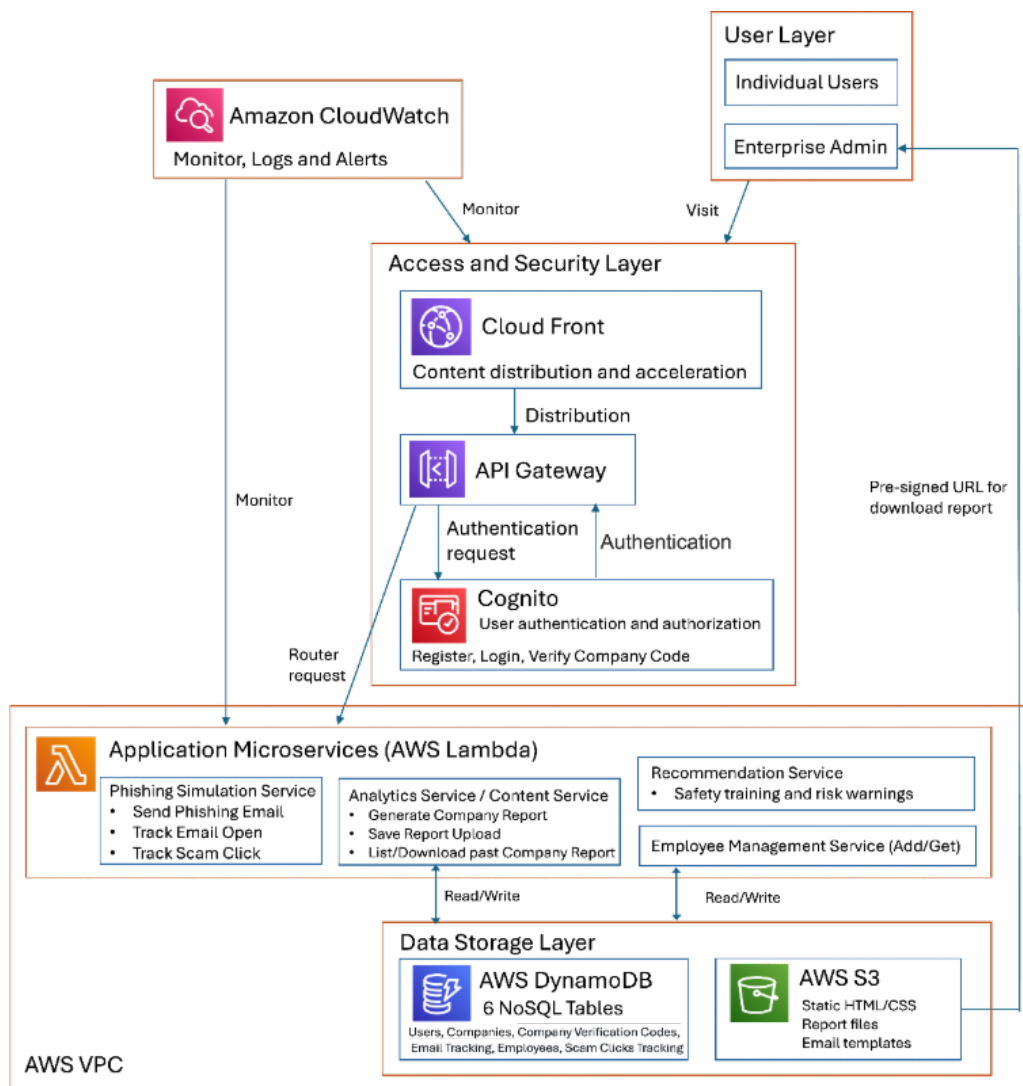


Figure 1: Architecture of our AWS-based anti-phishing training platform

3.2 Authentication and User Management

AWS Cognito manages user identity through a user pool (**ThinkBeforeClick-users**) supporting two types: individual (free signup with email verification) and enterprise (registration requires company verification code, Company ID, and admin credentials). API Gateway endpoints (**/register**, **/login**, **/verify-code**) trigger Lambda functions for user creation and validation. Cognito attributes enable role-based access control.

3.3 API Gateway and Lambda Functions

Amazon API Gateway provides secure entry points with throttling, validation, and authentication. AWS Lambda implements stateless business logic across several categories:

3.3.1 Authentication Services

User Login Service (CognitoLogin.py): This function authenticates users by accepting userType, username/email, and password as inputs. It stores user data in AWS Cognito User Pool and returns user attributes (userType, role, organizationType, adminUsername) along with appropriate HTTP status codes. The function supports dual authentication flows: enterprise administrators can log in using custom usernames (automatically mapped to their email addresses), while individual users authenticate directly with their email. It implements the ADMIN_NO_SRP_AUTH flow and includes comprehensive error handling for authorization failures, missing users, and unverified accounts.

User Registration Service (CognitoRegist.py): This service handles new user registration by accepting email, password, userType, and role related attributes as inputs, generating a UUID based username (user_XXXXXXXXXX), and creating accounts in AWS Cognito User Pool with custom attributes for role based access control. It stores user data in DynamoDB tables: individual users are saved to ThinkBeforeClick Users with accountType "individual", while enterprise users trigger dual table operations creating company records in ThinkBeforeClick Companies and user records in Users table with company associations. The service automatically sends email verification via Cognito's sign_up method and returns the UserSub as userId for consistent cross service identification.

3.3.2 Employee Management

Add Employee Service (add_employee.py): This service adds employees to enterprise accounts using email and companyId. It follows a "find or create" pattern that searches for existing Cognito users via email filter. For new users, it creates Cognito accounts with suppressed email notifications, sets default passwords, and marks emails as verified. It generates a unique employeeId (emp_XXXXXXXXXXXX) and stores employee data in two DynamoDB tables: ThinkBeforeClick-Users (accountType "employee" and company association) and ThinkBeforeClick Employees (initialized tracking metrics set to 0). The service includes retry logic for duplicate username/alias errors and uses conditional expressions to prevent duplicate records, returning the employeeId and creation status.

Get Employees Service (get_employees.py): This function retrieves the complete list of employees for a specific company. It accepts a companyId path parameter from API Gateway and queries the ThinkBeforeClick Employees table using a Global Secondary Index (GSI) named "CompanyIndex" with companyId as the partition key. If the query operation fails (possibly due to missing GSI configuration), it falls back to a scan operation with a filter expression. The returned employee records include all tracking metrics (sentEmails, openedEmails, clickedScams) and are sorted by addedAt timestamp in descending order to show recently added employees first. A custom DecimalEncoder class is implemented to convert DynamoDB Decimal types to standard Python int or float types for proper JSON serialization.

3.3.3 Email Simulation Services

Send Phishing Email Service (send_phishing_email.py): This service delivers phishing simulation emails by accepting employeeId, templateId (template1-template10), and recipient email as inputs, using Amazon SES with ten predefined templates that mimic real Singapore organizations (DBS Bank, SingPost, IRAS, Shopee, LinkedIn, SP Group, LTA, PropertyGuru, NUS, Carousell). Each template is carefully designed to replicate common phishing patterns observed in Singapore, including urgent payment requests, package delivery notifica-

tions, tax refund claims, and promotional offers. The service generates a unique trackingId (track_XXXXXXXXXXXXXXXXX format) and creates tracking records in ThinkBeforeClick EmailTracking table with initial state (isOpen: False, openedAt: None, scamClicks: []). The service constructs HTML emails with embedded phishing links pointing to CloudFront-hosted pages containing the trackingId parameter, sends emails via SES with scenario matched sender names for realism, and atomically increments the employee's sentEmails counter in the Employees table upon successful delivery.

Track Email Open Service (track_email_open.py): This function records when an employee opens a phishing simulation email, typically triggered by loading the template page. It accepts a trackingId path parameter and retrieves the corresponding record from the ThinkBeforeClick EmailTracking table using get_item. The function checks the isOpen boolean flag to determine if this is the first open event. If the email hasn't been opened before, it updates the tracking record with isOpen: True and the current UTC timestamp in ISO 8601 format, then atomically increments the employee's openedEmails counter in the Employees table. This ensures that multiple opens of the same email are not double-counted in the metrics.

Track Scam Click Service (track_scam_click.py): This function monitors when employees click on malicious links or interact with scam elements within phishing templates. It receives trackingId and scamType in the POST request body. After validating the tracking record existence, it generates a unique clickId incorporating the trackingId, scamType, and Unix timestamp to ensure uniqueness. A new record is created in the ThinkBeforeClick ScamClicks table containing full context including companyId, employeeId, employeeName, templateId, scamType, and clickedAt timestamp. Unlike email opens, multiple clicks on the same or different scam elements are all recorded individually to provide granular analytics on employee vulnerability patterns and specific attack vectors that are most effective.

3.3.4 Report Management Services

Generate Company Report Service (generate_company_report.py): This service generates comprehensive phishing simulation analytics by accepting companyId as input and querying three DynamoDB tables via CompanyIndex GSI: ThinkBeforeClick-EmailTracking (simulation records), ThinkBeforeClick ScamClicks (click events), and ThinkBeforeClick Employees (employee data). It calculates aggregate metrics including total simulations count, opened count, open rate, and click rate. For employee ranking, it sorts employees by a composite key (clicked-Scams, openedEmails, sentEmails) to identify the most vulnerable employees requiring immediate training intervention. The service also analyzes scam type popularity by aggregating click counts per scamType and evaluates template performance with individual open/click rates per templateId. The service returns JSON formatted analytics using DecimalEncoder for compatibility, providing enterprise administrators with actionable insights for targeted security training.

Verify Company Code Service (VerifyCompanyCode.py): This function validates company registration codes for enterprise account activation. It extracts the code parameter from either the request body or query string parameters. The function performs a consistent read operation on the ThinkBeforeClick CompanyVerificationCodes DynamoDB table using the code as the primary key. It returns the code status attribute value (valid, invalid, or not_found) to indicate whether the company code can be used for registration.

Save Report Upload Service (SaveReportUpload.py): This function handles the persistent storage of generated PDF reports to Amazon S3. It accepts base64 encoded PDF data in the request body, decodes it to binary, and uploads it to the configured S3 bucket. The filename is timestamped using the format company_YYYYMMDD-HHMMSS.pdf to prevent naming collisions and maintain chronological ordering. After successful upload, the function generates a presigned URL valid for 3600 seconds, allowing immediate download without requiring additional authentication.

List Company Reports Service (ListCompanyReports.py): This function retrieves the historical list of reports for a company from S3. It uses S3's list_objects_v2 API with pagination support to retrieve all objects under the prefix enterprise/report/{companyId}/. The function filters for PDF files and sorts results by modification date in descending order.

Download Past Report Service (DownloadPastReport.py): This function provides secure download access to previously generated reports. It accepts companyId as a path parameter and filename as a query parameter. Security validation is performed to prevent path traversal attacks. The function verifies file existence before generating the presigned URL, returning a 404 error if the file does not exist.

3.4 Domain Configuration

Our application uses the custom domain `thinkbeforeclick.com`, which was purchased through Alibaba Cloud domain registration services. To integrate this domain with our AWS infrastructure, we configured DNS records in Alibaba Cloud's DNS management console. CNAME records were created pointing to our AWS CloudFront distribution domain for frontend content delivery and to our API Gateway custom domain for backend API endpoints. AWS Certificate Manager (ACM) was used to provision SSL/TLS certificates for secure HTTPS communication.

3.5 Data Storage

DynamoDB Tables: Six tables store structured data with optimized partition keys and GSIs (Table 3):

Table 3: DynamoDB Tables

Table	Purpose	Key
Users	User profiles, account type, companyId	userId
Companies	Enterprise information	companyId
Employees	Employee details, tracking metrics	employeeId
EmailTracking	Phishing simulation tracking	trackingId
CompanyVerificationCodes	Product verification codes	code
ScamClicks	Click outcomes, scam types	clickId

Each table was assigned an appropriate partition key to support common access patterns and maintain efficient queries. DynamoDB provides single-digit millisecond read/write performance, automatic scaling, and serverless operation.

Amazon S3: Stores training materials, PDF reports, and frontend assets including HTML, CSS, and JavaScript files.

3.6 Reliability and Monitoring

To enhance reliability and reduce operational overhead: Amazon CloudWatch collects logs and performance metrics from API Gateway, Lambda, and DynamoDB for centralized monitoring and alerting. AWS IAM enforces least-privilege access control among services. Amazon SES is integrated through Lambda for sending user verification and phishing simulation emails. This design ensures that our entire platform remains serverless, cost-efficient, secure, and scalable, with minimal maintenance overhead.

3.7 Deployment and System Operation

The application is deployed on AWS using the default VPC environment, which provides basic network isolation, routing, and security group configuration out-of-the-box. This setup simplifies

deployment and allows the system to leverage AWS-managed reliability and networking without the need for custom subnet or routing configuration. The deployment process is currently manual through the AWS Management Console, where the main components (Lambda functions, API Gateway, DynamoDB, and S3) are created and configured.

3.8 System Evaluation and KPIs

To evaluate system performance and operational reliability, we assess two primary KPIs: Lambda Execution Time and API Latency.

Lambda Performance: The GetEmployees function maintains 239ms average execution time over six weeks with 100% success rate across 223 invocations (Figure 2). CloudWatch's time-series data shows that the function consistently remains well within the system's performance target of below 500ms.

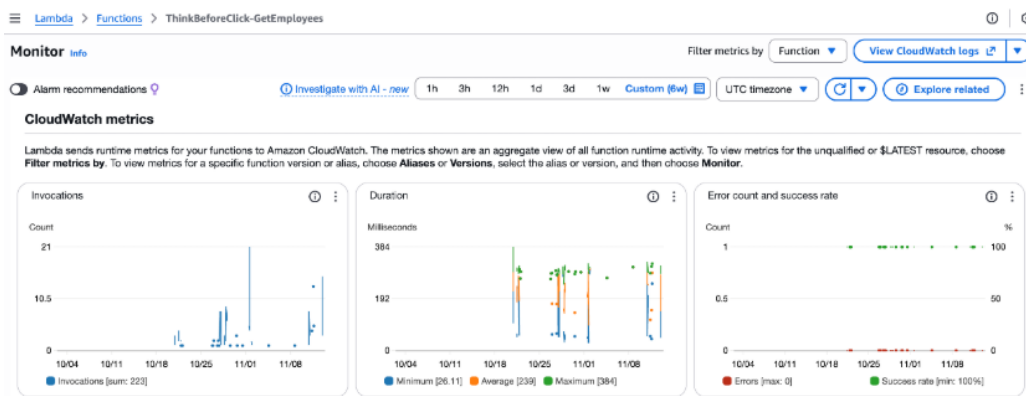


Figure 2: CloudWatch metrics for GetEmployees Lambda (six weeks)

API Latency: Four-week P99 metrics show 1.53s maximum latency and 3.05s integration latency (Figure 3), meeting performance targets. These results indicate that the majority of API requests complete within acceptable thresholds.

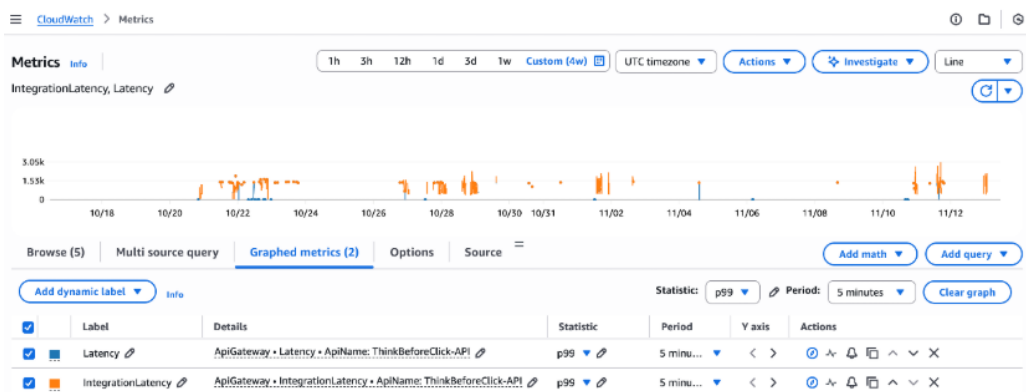


Figure 3: P99 Latency metrics (four weeks)

3.9 User Journey

3.9.1 Individual User Journey (Free)

The individual user journey consists of five key stages. First, users arrive at the platform homepage and click "Start Now" for individuals. Second, users create a free account by providing email and password, then complete email verification before logging in. Third, users enter

the individual learning dashboard where they can access interactive training modules about phishing awareness. Fourth, users watch tutorial videos, review real-world scam examples across email, SMS, and social media channels, and complete adaptive quizzes to test their knowledge. Finally, users view their personal progress report showing training completion status and areas for improvement.

3.9.2 Enterprise User Journey (Paid)

The enterprise user journey is more comprehensive and consists of nine stages. Company admins begin by arriving at the platform homepage and selecting the "Enterprise" option. They then register by entering their verification code, providing company email, creating a password, selecting their organization type, and creating a unique Company ID. After email verification, admins log in with their Company ID, email, and password to access the enterprise dashboard.

Once logged in, admins add employees to the system by providing their names and email addresses. The system tracks all employees under the company account. Admins then select from 10 phishing email templates simulating real Singapore-based scams (including DBS Bank alerts, SingPost delivery notifications, IRAS tax refunds, Shopee promotions, LinkedIn job offers, SP Group utility bills, LTA parking fines, PropertyGuru property alerts, NUS admission notices, and Carousell purchase confirmations) and send them to selected employees.

The system provides real-time tracking when employees open emails and click on suspicious links. Each interaction is logged with timestamps and employee details. When an employee clicks a phishing link, they are immediately redirected to an educational page explaining what they missed and how to identify such threats in the future. Admins can then generate comprehensive reports showing email open rates, click-through rates, employee vulnerability rankings, most clicked scam types, and template performance metrics. Finally, admins can download past reports, view historical data, and track improvement over time to measure training effectiveness.

This dual approach ensures that individuals receive direct training and self-assessment, while enterprises can proactively test employees, identify vulnerabilities, and provide targeted education based on actual behavior patterns. Additionally, employees added by enterprise admins can log in as individual users to access personal training modules.

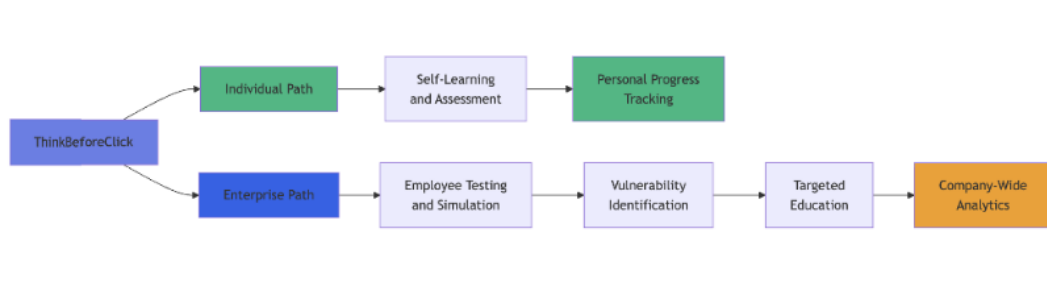


Figure 4: User journey comparison

4 User Review and Future Work

4.1 User Feedback Collection

To validate our platform design and identify improvement opportunities, we conducted user testing sessions with two distinct user groups:

- **Individual Users (n=15):** Members of the general public aged 25-65, representing diverse digital literacy levels and occupations including students, retirees, and working professionals.
- **Enterprise Decision-Makers (n=8):** IT managers and security officers from small to medium-sized organizations (50-500 employees) across healthcare, education, finance, and

technology sectors.

Feedback was collected through structured interviews, post-use surveys, and usability observation sessions conducted over a two-week period in October 2025.

4.2 Key Findings from User Reviews

4.2.1 Positive Feedback

Users appreciated several aspects of our platform. The effectiveness of interactive learning was highlighted, with users valuing the hands-on approach to phishing awareness. One IT manager noted: "The interactive simulations are far more engaging than our previous PowerPoint-based training." Individual users valued the permanently free access, with 87% rating the training modules as "useful" or "very useful." Enterprise users highlighted the CTA-level tracking as particularly valuable for obtaining actionable intelligence. The ability to tailor phishing templates to company domains and local scam patterns was identified as a key differentiator.

4.2.2 Areas for Improvement

Based on user feedback, we identified six key enhancement opportunities:

1. **Fully Managed Service:** Enterprise users requested a turnkey solution where our team handles end-to-end campaign execution.
2. **Bulk Employee Management:** Current individual email entry is tedious. We will implement CSV batch upload with validation checks.
3. **Individual-Enterprise Integration:** Users want employees' personal learning progress linked to corporate profiles.
4. **Self-Service Template Builder:** Security teams want a drag-and-drop editor for rapid iteration.
5. **Community Forum:** Individual users requested peer-learning spaces to share experiences.
6. **Balanced Training Content:** Current modules over-emphasize malicious content. We will add mixed scenarios.

4.3 User Satisfaction Metrics

Post-testing surveys showed strong validation: Overall satisfaction averaged 4.2/5.0 (individuals) and 4.5/5.0 (enterprises), with 82-87% likelihood to recommend. Notably, 89% reported increased confidence in identifying phishing attempts, and interface usability scored 4.3/5.0.

4.4 Future Development Roadmap

Short-term (3-6 months): CSV bulk upload, self-service template editor, Learning Portfolio, balanced training scenarios.

Medium-term (6-12 months): Fully Managed service tier, community forum, AI-powered threat detection, mobile app, multi-language support.

Long-term (12+ months): Behavioral vulnerability analytics, enterprise tool integrations, industry-specific modules, real-time threat intelligence feed, Southeast Asia expansion.

5 Conclusion

This project has successfully developed an interactive, adaptive fraud and phishing training platform that addresses critical gaps in current cybersecurity awareness measures. By offering a dual-focus approach—serving both individual users through a permanently free public track and enterprises through sophisticated phishing simulation tools—we provide comprehensive scam education at scale.

Our AWS-based serverless architecture delivers significant cost advantages (45% savings over on-premise solutions), automatic scalability, and high reliability. The platform’s key differentiators include demographic-aware targeting, granular CTA-level tracking, and deep customization capabilities tailored to Singapore’s local scam patterns. User testing has validated the platform’s effectiveness, with strong satisfaction scores and clear evidence of improved phishing awareness.

As cyber threats continue to evolve, our platform provides organizations and individuals with the tools they need to stay ahead of attackers through realistic, evidence-based training that adapts to emerging threats. The roadmap outlined in Section 4 ensures continuous improvement and expansion to meet future cybersecurity challenges.

6 Code Explanation

6.1 Public Code Repository

Our project’s complete source code is publicly available and hosted on GitHub. This repository includes all frontend assets, backend Lambda functions, and detailed documentation.

Public URL: <https://github.com/wuyibaobao/CS5224-ThinkBeforeClick>

6.2 Service-to-Code Mapping

The following table maps the core application features to their corresponding backend Lambda functions and DynamoDB database tables, demonstrating our microservice architecture where each Lambda function is responsible for a single business task.

Table 4: Core Logic Map

Feature	Lambda Function	Database
Authentication	CognitoLogin, CognitoRegist	Users, Companies
Employee Mgmt	add_employee, get_employees	Employees, Users
Email Simulation	send_phishing_email	EmailTracking
Tracking	track_email_open, track_scam_click	EmailTracking, Scam-Clicks
Reporting	generate_company_report, Save/List/DownloadReport	All tables, S3
Verification	VerifyCompanyCode	CompanyVerificationCodes

References

- [1] Ang, A. (2025, August 23). Over \$30,000 lost in new scam in Singapore involving requests for school fees by impersonators. *The Straits Times*. <https://www.straitstimes.com/singapore/courts-crime/over-30000-lost-in-new-scam-in-singapore-involving-requests-for-school-fees-by-impersonators>
- [2] Chua, N. (2025, August 30). Scam victims in Singapore lost \$456m in first half of 2025 with almost 20,000 cases reported. *The Straits Times*. <https://www.straitstimes.com/singapore/scam-victims-in-spore-lost-456m-in-first-half-of-2025-with-almost-20000-cases-reported>